Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

INSA | LYON



Network Access Control

Walid Bechkit, INSA-Lyon, INRIA-CITI

citi lab

Inria INVENTEURS DU MONDE NUMÉRIQUE

membre de UNIVERSITÉ DE LYON

Course objectives

- Understand the concept, features, and components of a network access control (NAC) system
- Understand 802.1X (and the concept of PNAC)
- Understand the EAP protocol
- Understand the role of AAA protocols and study the specific case of the Radius protocol and its extensions
- Understand 802.1x, EAP, and RADIUS interoperability
- Understand the specific features of Wi-Fi

Key references

- **Network authentication network. Radius. 802.1x-EA-FreeRadius**. Serge Bordères, Eyrolles, 2007
- **Comparative Study of Network Access Control Technologies**, Hasham Ud-Din Qazi, Final Thesis, 2007 Linköpings universitet.
- **Network Access Control White** P a p e r , Enterasys
- **Study of the implementation of a network access control solution using the 802.1X protocol**, Mamadou Bobo Diallo, Master's thesis final engineering thesis, 2017.
- Teaching resources from the University of Pau and Pays d'Adour (AAA and 802.1X practicals)
- **Wi-Fi security – WEP, WPA, and WPA2** Guillaume Lehembre, 2006
- **802.11 Wireless Networks Security and Analysis**, Alan Holt and Chi-Yu Huang, Springer, 2010
- **Wi-Fi Professional - The Standard 802.11, Deployment Deployment, Security,** Aurélien Géron, Paperback, 2009

Introduction

NAC: source and some definitions

- An old technical term initially introduced as an authentication and authorization solution.

- "Determine who and what is allowed to communicate on the network from a particular location and at a given time (where and when)."
- "Subject access to resources by endpoints to a defined security policy."
- "Ensure that every device that connects is authenticated and subject to the application of security rules. Automate the administration of isolation, quarantine, and threats."

NAC: more than a simple authentication

- In addition to authenticating users and devices, which are at the heart of NAC, it must be able to:
  - restrict the data that a user can access;
  - regulate the options available to users once they are connected;
  - execute applications and permanent applications and prevention permanent of risks (detection of spyware , signature update verification, etc.)
  - etc.

NAC: NAC features

1. **Node detection:** ARP requests, EAP authentication requests, DHCP requests, etc.)

2. **Authentication**: determining whether the user or device is who they claim to be

3. **Posture assessment:** verification of version numbers, updates, patches, IDS signatures, certificate validity, etc.

4. **Authorization:** assigning access rights/privileges.

NAC: NAC features

5. **Enforcement of security policy** (full access, limited access, quarantine, access denied): Implemented by Access Control Lists (ACLs), VLANs, firewall rules (URL lists, allowed ports, etc.), etc.
6. **Post-admission control (and accounting):** users, devices, and sessions are monitored to detect malicious activity (worms, viruses, policy violations, etc.).
7. **Quarantine**
8. **Remediation**

NAC: components

- **Client: endpoint system**
  Machine/user wishing to access resources
- **Compliance system (Policy Servers)**
  e.g., radius server (authentication, authorization, accounting)
- **The enforcement system (enforcement points)**
  e.g., access point, switch, router, firewall, etc.

  Assign and apply VLAN rules / apply access controls N 2, 3, or 4, etc.

- **Quarantine network**
- **Remediation server**

NAC: Main solutions

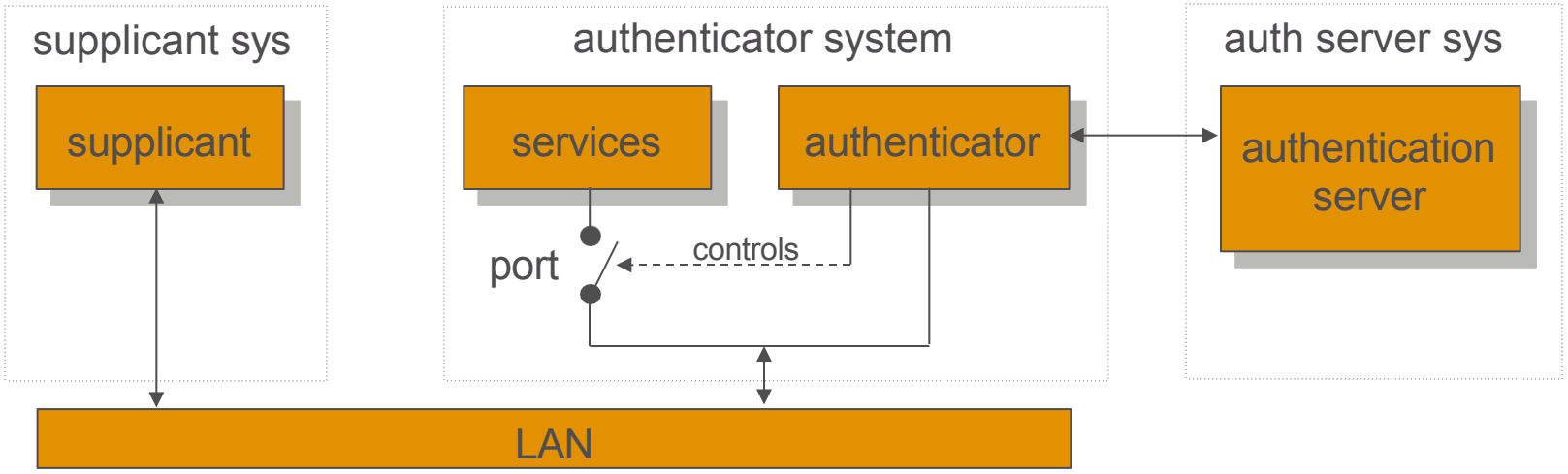
Proprietary solutions:

- Network Admission Control (NAC) = Identity Services Engine (ISE) - Cisco
- Aruba ClearPass - Aruba
- Unified Access Control (UAC) - Juniper Networks, Inc.
- Network Access Protection (NAP) - Microsoft Corp.

Standards:

- 802.1X: IEEE standard (port-based Network Access Control)
- Trusted Network Connect (TNC) by the Trusted Computing Group: based on IEEE's 802.1X, EAP, TLS, and RADIUS, and adds features such as upper layers

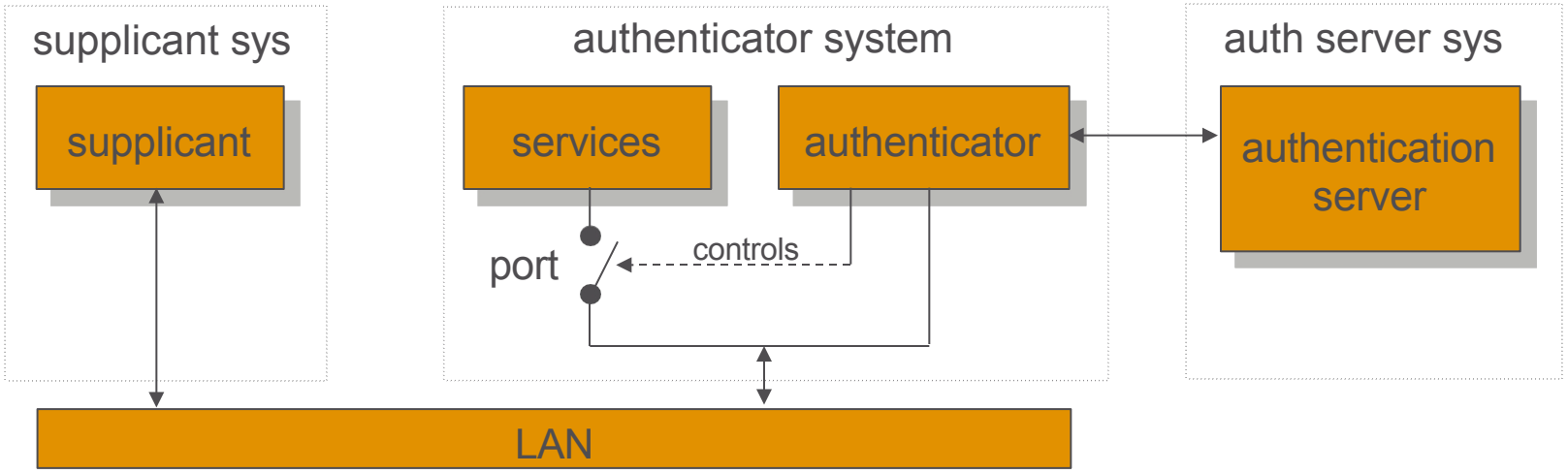
PNAC: 802.1X authentication model



- A standard that provides an authentication mechanism for devices wishing to connect to a local network (wired or wireless)

- The client (supplicant) requests access to a service (connect to the network)
- The controller (authenticator) controls access to the service (port status)
- The authentication server authorizes access to the service

PNAC: 802.1X authentication model

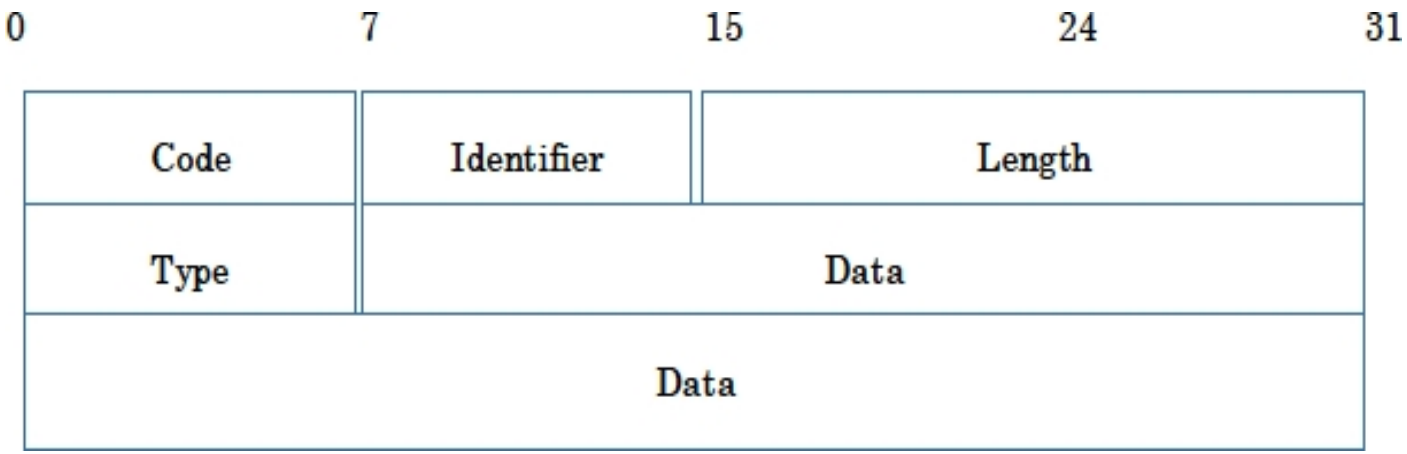


- Uses EAP to transport authentication information (uncontrolled port)
- Relies on a protocol protocol (authentication, authorization, and accountability) such as RADIUS, TACACS+, Diameter, etc.:
- The 802.1X standard gives RADIUS as the only example of implementation, but any AAA protocol can be used.

EAP protocol

- **EAP (Extensible Authentication Protocol) [RFC 2284, 3748, 5247]**
  - Protocol designed for transporting authentication messages (e.g., TLS, TTLS, PSK, MD5, etc.).
  - Please note: This is not an authentication protocol.
  - Four types of messages:
    - EAP request –supplicant→ authentication server
    - EAP response –authentication server→ supplicant
    - EAP success – successful authentication
    - EAP failure – authentication failure
  - The controller plays a passive role and does not know the content of the messages; it only recognizes EAP success and failure

EAP protocol



Code: type of message contained in the frame (Request, Response, Success, Failure)

Identifier: allows request and response frames to be correlated.

Length: length of the frame.

Type: type of protocol used (EAP MD5; EAP TLS PEAP; EAP TTLS; etc.)

Data: the data carried by the frame (depending on the type)

AAA protocol

Client/server protocols that guarantee:

- **Authentication** => Who is speaking?
  Identify a user and prove that they are who they claim to be
- **Authorization** => What are their "rights"?
  Assign rights and privileges to users (access rights to resources and services)
- **Accounting** => What are they doing?
  Record all information related to the use of a service (type of service, start of service, traffic related to the service)

Examples of AAA protocols: **Radius**, Diameter, TACACS

Radius protocol

- **RADIUS:** Remote Authentication Dial-In User Service
- AAA protocol defined in RFC 2865 (Authentication and Authorization) and RFC 2866 (Account Management)
- Uses UDP port 1812 to exchange data related to user authentication
- Uses UDP port 1813 for account management to ensure traceability

Radius authentication

- Reminder: This is the process that ensures the legitimacy of an access request made by an entity
- The Radius client (called NAS) presents an identifier to the server
- The server verifies that the client is present in its database and that the person presenting this identifier can prove that they are the owner.

- Most common methods:
  - MAC address (weak, no proof)
  - Login/password
  - Certificate

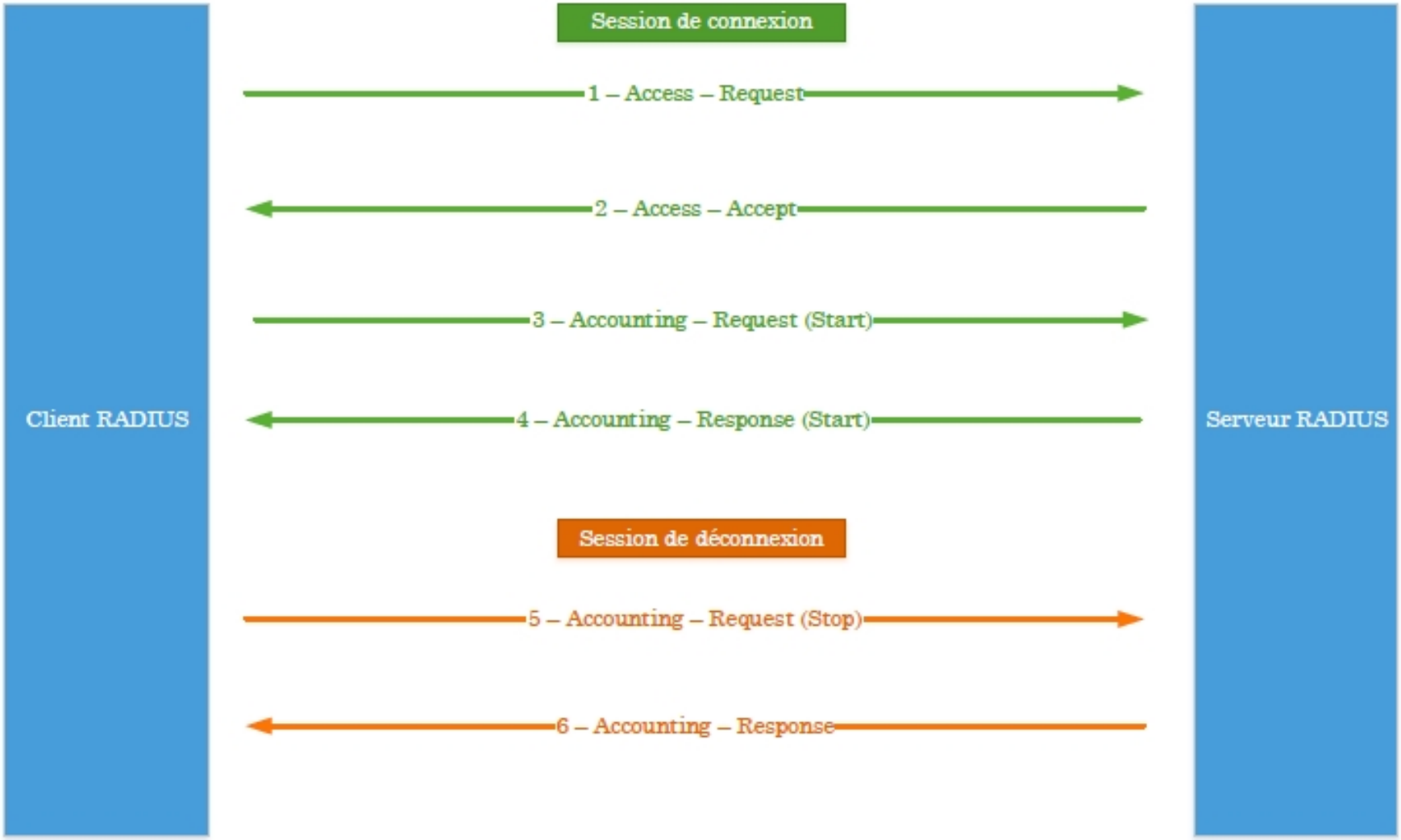
Radius authorization

- Full access, partial access, or denial of access to a network
- Assign a VLAN number
- Set ACLs
- Assign an IP address
- Execute a command (filtering, routing, etc.)
- ...

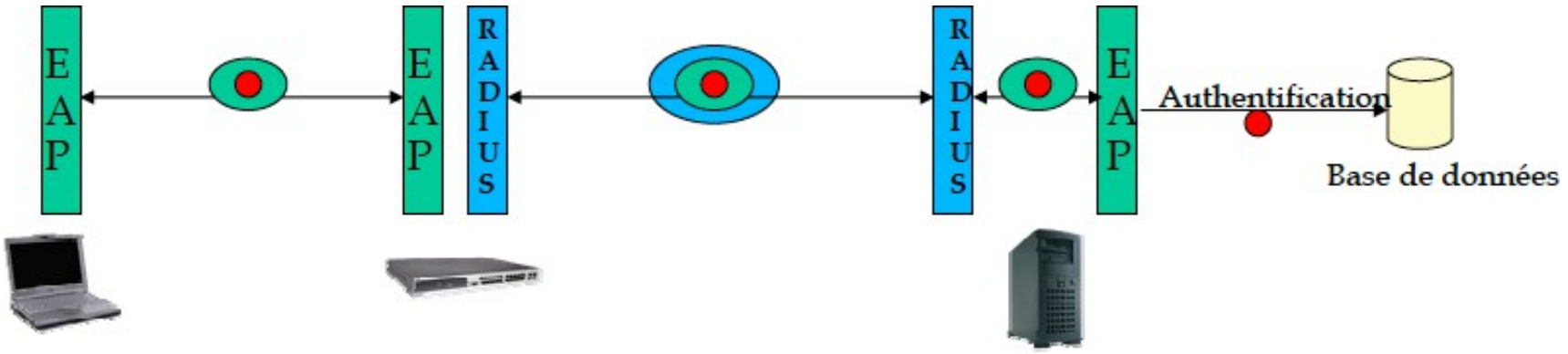
Radius accounting

- Track the start and end of sessions
- Track resources (such as time, packets, bytes) used during sessions
- Enable ISPs, among others, to bill their customers accurately

Radius operation



802.1x, EAP, RADIUS interoperability



Protocole d'authentification (charge utile)

Encapsulage EAP

Encapsulage Radius

Radius database

- The database associated with the Radius server contains authentication and/or authorization information.
- This database is not specified by the Radius protocol
- With FreeRadius, for example:
  - Flat file (users): Authorizations and/or authentication
  - LDAP database
  - Windows domain via Active Directory
  - SQL database: Authorization
  - …

Radius database

- Example of a flat file (users): Authorizations and authentication

```
DEFAULT
                Tunnel-Type = VLAN,
                Fall-Through = 1


DEFAULT Nas-Port == 10, Nas-IP-Address == 192.168.0.3
                Idle-Timeout = 600,
                Fall-Through = 1

walid User-Password := "test"
                Tunnel-Private-Group-Id = 4

francois User-Password := "test123"
                Tunnel-Private-Group-Id = 5
```

Radius authentication methods

Type d'authentification	Emetteur de l'identifiant	Protocole
adresse MAC	l'équipement réseau	RADIUS
login/password certificat	le poste utilisateur (supplicant)	RADIUS + 802.1X + EAP

Radius authentication methods

Radius-MAC => Authentication by MAC addresses→ Not recommended, especially for wireless networks

EAP-MD5 => No mutual authentication between client and Radius server; client authenticates using a password

EAP-PSK => mutual authentication between client and server using a shared secret

EAP-TLS => Mutual authentication using certificates

- TLS Handshake - Mutual authentication by certificates
- The identifier in the database is the CN of the certificate

Radius authentication methods

EAP-TLS => problem
need to distribute certificates to all users or machines

EAP-TTLS and PEAP => Server authentication via its certificate and client authentication via login/password

Two phases:

- TLS Handshake – Server authentication via certificate
- TLS Record – Creation of an encrypted tunnel. The password authentication protocol circulates in the encrypted tunnel

Radius implementations

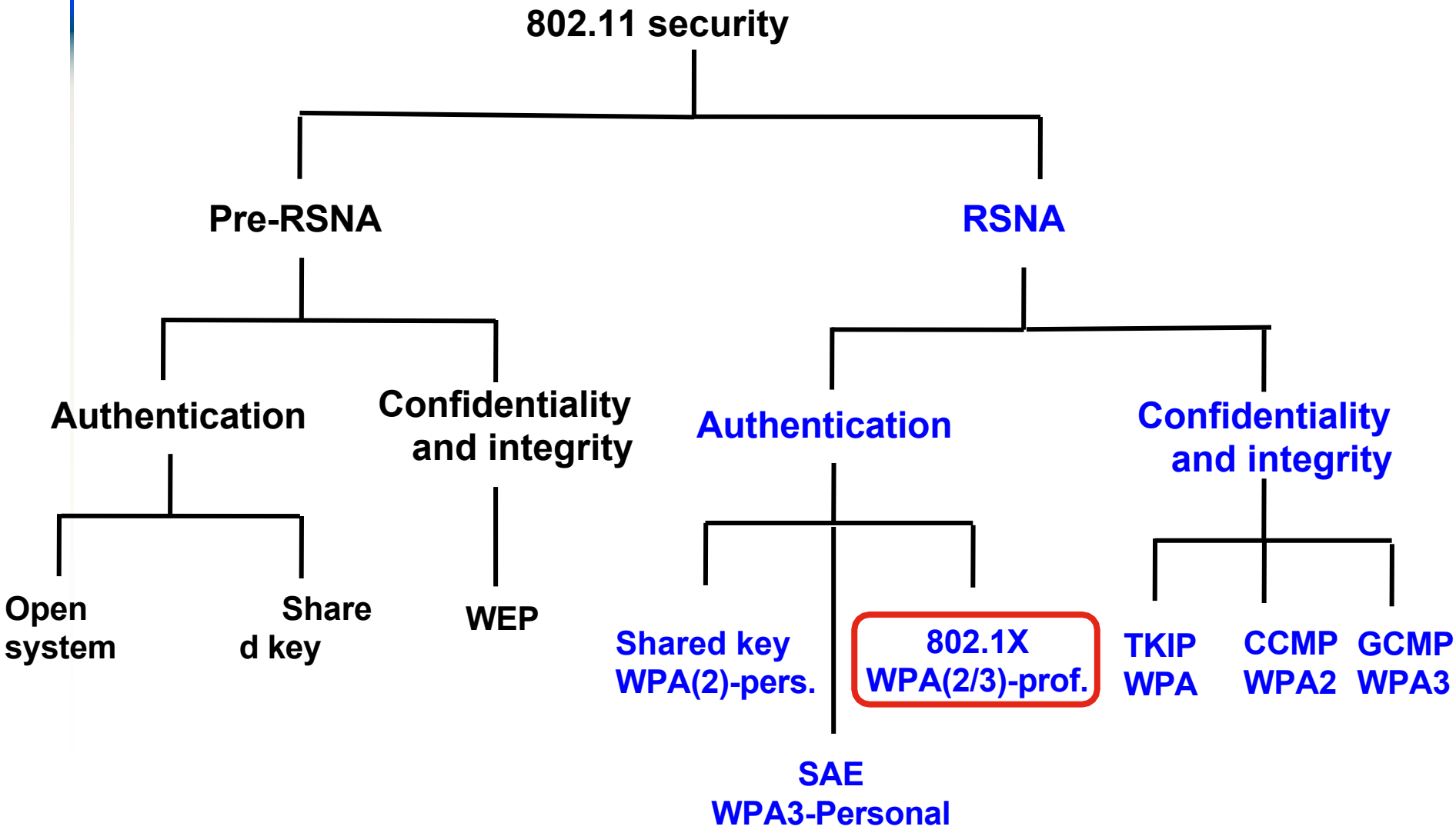
Open source implementations

- Freeradius
- Openradius
- Gnuradius

Commercial implementations

- ACS (Cisco)
- IAS (Microsoft)

Special case: WiFi



Phase 2: 802.1X / WiFi 802.11i correspondence

- → supplicant Mobile station (STA)
- → authenticator Access point (AP)
- Authentication server→ Server running on the access point or on a dedicated machine

- In addition, 802.11i includes:
  - Successful authentication ends with the sending of a session key in addition to the positive authentication response

Thank you ☺